Segurança de Redes

Network Security

Mestrado em Cibersegurança (MCS)

Mestrado em Redes de Computadores (MRC)

Departamento de Informática, Universidade do Minho

Ivo Miguel Menezes Silva

1° Semestre (26/27)

Adapted from Prof. Paulo Carvalho's (Dept. Informática – UMinho) slides, which were originally based on:
J.F Kurose and K.W. Ross, "Computer Networking: A Top-Down Approach, 8th ed., Pearson, 2020. Teaching material.

Outline

1. Introduction: Network Security Threats and Attacks
2. Securing End-to-End Connections
   - Transport Layer Security (TLS)
3. Security at Transport Layer:
   - TCP, UDP, QUIC
4. Security Network Layer
   - IP/ICMP, IPSec, VPNs, IPv6 Security



Image created with ChatGPT (OpenAI GPT-5.5)

© iSilva 2026

What is cybersecurity?

def Cybersecurity

"Prevention of damage to, protection of, and restoration of computers, electronic communications systems, electronic communications services, wire communication, and electronic communication, including information contained therein, to ensure its availability, integrity, authentication, confidentiality, and nonrepudiation."

[NIST, Computer Security Resource Center]

© iSilva 2026

What is network security?

def Network Security

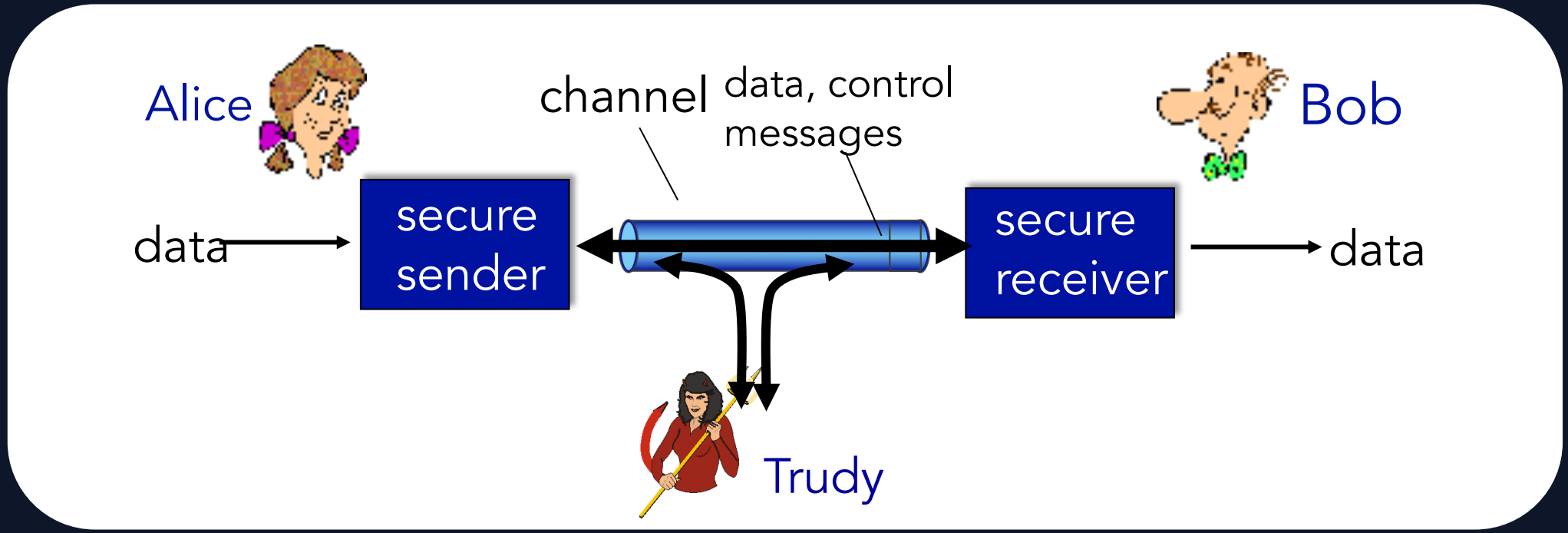
"Network security is the protection of the underlying **networking infrastructure** from unauthorized access, misuse, or theft. It involves creating a secure infrastructure for devices, protocols, users, and applications to work in a secure manner."

[CISCO]

© iSilva 2026

Friends and enemies: Alice, Bob, Trudy

- well-known in network security world
- Bob, Alice (lovers!) want to communicate “securely”
- Trudy (intruder) may intercept, delete, add messages



© iSilva 2026

Friends and enemies: Alice, Bob, Trudy

Who might Bob and Alice be?

- … well, *real-life* Bobs and Alices!
- web browser/server for electronic transactions (e.g., on-line purchases)
- on-line banking client/server
- DNS service and servers
- BGP service and servers (routers exchanging routing table updates)
- …
- any system or entity in a public or private **network**

© iSilva 2026

Trudy: there are bad guys (and girls) out there!

Q: What can a "bad guy" do?

A: A lot! (see also section 1.6 of book [Kurose and Ross, 2020])

- eavesdrop: intercept messages
- actively insert messages into connection
- impersonation: can fake (spoof) source address in packet (or any field in packet)
- hijacking: "take over" ongoing connection by removing sender or receiver, inserting himself in place
- denial of service: prevent service from being used by others (e.g., by overloading resources)

© iSilva 2026

Network Security

🎯 GOAL

Understand network security within TCP/IP protocol stack, specifically at the following levels:

- Application;
- Transport;
- Network level;
- Link-layer level.

© iSilva 2026

Network Security

Security needs are transversal to TCP/IP protocol stack. Recall that:

- TCP/IP was not originally designed with security concerns in mind
- application user data may be tampered when in transit
- transport connections may be reset or hijacked
- network IP addresses and routing may be spoofed
- link layer MAC addresses may be spoofed or devices hijacked

- not enough to focus on a particular functional level
  - protection at higher layers do not eliminate threats at lower ones

© iSilva 2026

Cybersecurity / Network Security Principles

Confidentiality

- Only the sender and the intended receiver should "understand" the content of a message. The sender **encrypts** the message and the receiver **decrypts** it.

Integrity

- The sender and receiver want to ensure that the message is not altered in transit, or later, without detection.

Authentication

- The sender and receiver need to confirm each other's identity.

Access and Availability

- Data and services must remain accessible and available to authorized users.

Non-repudiation

- A party should not be able to deny having sent or received a message or transaction.

© iSilva 2026

Security Concerns

lack of confidentiality

- an intruder can access sensitive or private data, or context

lack integrity of messages

- an intruder can change or delete message contents both in transit or received without being detected

lack of authentication

- an intruder can assume the identity of a legitimate user; no guarantee to proof the identity of parties

limited access and availability

- access to data or services can be stolen, conditioned or blocked

repudiation

- a sender or receiver can deny sending or receiving a message or performing a transaction as there are no proof mechanisms (system logs are not enough)

© iSilva 2026

Types of Network Security Threats

Phishing – deceptive tactics (masquerade as legitim e-mail messages, websites, etc.) to elude unsuspecting users into share sensitive data such as passwords, financial details, or personal data (also SQL injection, malware, etc.)

- A: promote cybersecurity awareness, two-factor authentication

DNS Spoofing – manipulation of domain name system resolution to redirect users to malicious websites or intercept sensitive information

- A: use of DNSSEC, DNS filtering and monitoring

Distributed Denial of Service (DDoS) attacks – distributed attack aiming at disrupting services by overwhelming a target system with traffic, exhausting resources and limiting legitimate users

- A: use of detection, filtering, analytical and blocking techniques; reduce systems exposure

Man-in-the-Middle (MitM) attacks – interception of communication parties, allowing the attacker to eavesdrop, modify, or inject malicious content into the data stream

- A: use of robust encryption standards and network monitoring

© iSilva 2026

Other Cybersecurity Threats (1/2)

Ransomware – encrypting (critical) data and demanding huge ransom payments for decryption keys

- A: robust backup strategies, regular security patches

IoT vulnerabilities – exploiting security breaches of IoT devices for DDoS

- A: strong passwords, regular firmware updates, net segregation of critical devices

Mobile devices vulnerability – malware and exploiting vulnerabilities may result in data breaches and identity theft

- A: install security apps, regular OS updates, and trustable app downloads

Insider threats – malicious or negligent actions by individuals within an organization

- A: strict access controls, employee activity monitoring, and periodic security training

Supply Chain attacks – filtrating trusted vendors or suppliers to compromise a entire supply chain

- A: regular security (and vendor) assessments, robust incident response protocols

© iSilva 2026

Other Cybersecurity Threats (2/2)

AI-Powered attacks – leveraging AI to launch intelligent, sophisticated, automated attacks evading detection and security measures; improve social engineering

- A: use of AI-based security solutions as countermeasure

Advanced Persistent Threads (APTs) – sophisticated, long-term cyber-attacks targeting specific entities

- A: strong access controls, regular security assessments, detection and response technologies

Zero-day exploits – exploiting unknown software vulnerabilities, missing patches or lack of defences

- A: software patches, intrusion detection systems, and monitoring vulnerability databases

Cloud security risks – possible misconfigurations, data breaches, and unauthorized access to cloud environments

- A: strong authentication and encryption, and continuous monitoring of cloud environments

© iSilva 2026

DNS spoofing attacks

DNS spoofing is a DNS attack that alters name resolution so users are redirected to a fraudulent or attacker controlled destination instead of the legitimate one. In practice, it works by changing or forging DNS records or responses, often to send victims to fake websites or malicious IP addresses.

DNS server compromise

- attacker hijacks a DNS server and has access to the name resolution system
- able to change resource records (RR) to return malicious data

MitM

- attacker intercepts DNS queries and manipulates DNS server responses with malicious data

DNS cache poisoning (side effect)

- subsequent requests from other users or applications will get malicious data from DNS caching system
- in addition, the attacker may exploit TTL of entries in the DNS cache to ensure that malicious data persist

© iSilva 2026

DDoS attacks – volumetric attacks

DDoS volumetric attacks are attacks that flood a target with massive amounts of traffic to exhaust its bandwidth, making the service slow or unavailable to legitimate users. They often use botnets or amplification techniques such as DNS amplification to generate traffic far beyond what the attacker sends directly. There are different types of DDoS volumetric attacks.

SYN flooding

- attacker launches a massive number of TCP connection requests from clients (possibly using false source IP address to hide identity) to a target server
- at server, TCP replies with SYN/ACK and creates state for the connection
- clients don't send ACK, remaining the connection half open, exhausting memory at server
- A: use authentication cookies, and allocate state only if client is legitimate (e.g. SCTP)

IP, ICMP, UDP flooding

- attacker sends a large volume of traffic (e.g., *ping*) to the IP broadcast addresses of intermediary networks, with the source IP address spoofed (victim's IP address)

Slow flooding

- same principle but spread over a large time window; mixed with legitimate traffic; more difficult to detect

© iSilva 2026

DDoS attacks – protocol-based attacks

DDoS protocol-based attacks are attacks that exploit weaknesses in network protocols to exhaust connection or state resources and make a service unavailable. They do this by sending malformed, spoofed, or incomplete packets that force devices like servers, firewalls, or load balancers to spend resources handling fake communication.

© iSilva 2026

Reflection / Amplification

- attacker exploits vulnerabilities of application protocols (e.g. DNS, NTP, LDAP, SSDP) to launch IP spoofed queries, causing them to send an amplified response to the victim

DDoS attacks – protocol-based attacks

DDoS protocol-based attacks are attacks that exploit weaknesses in network protocols to exhaust connection or state resources and make a service unavailable. They do this by sending malformed, spoofed, or incomplete packets that force devices like servers, firewalls, or load balancers to spend resources handling fake communication.

Reflection / Amplification

- attacker exploits vulnerabilities of application protocols (e.g. DNS, NTP, LDAP, SSDP) to launch IP spoofed queries, causing them to send an amplified response to the victim



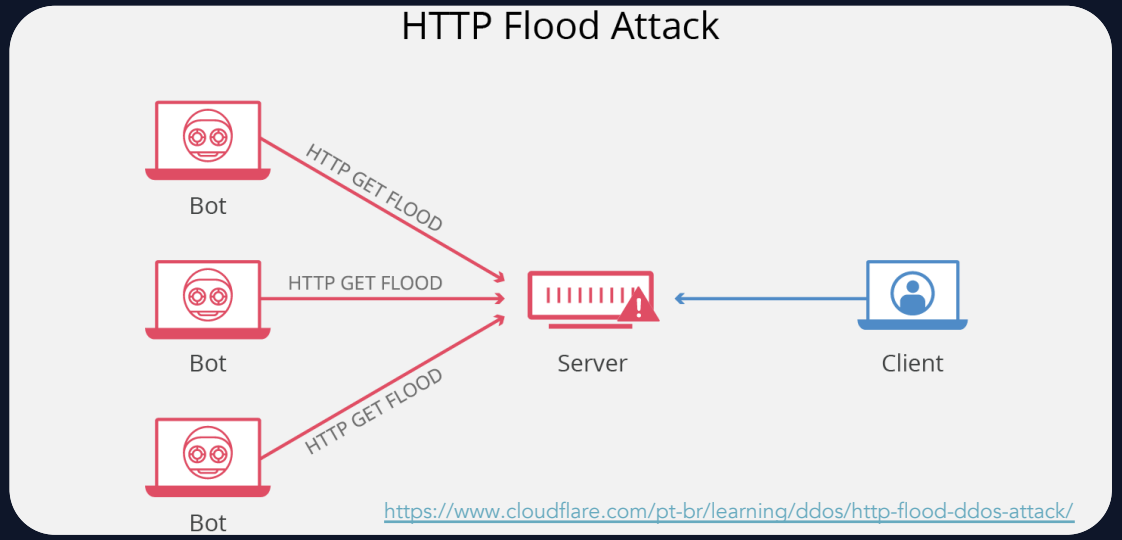
© iSilva 2026

DDoS attacks – Application layer attacks (1/3)

DDoS application layer attacks are attacks that target the application itself, usually at Layer 7, by sending many seemingly legitimate requests that exhaust server resources and make the service unavailable. They are often harder to detect because they can look like normal user traffic.

HTTP / HTTPS flooding

- attacker floods the target web server with HTTP / HTTPS requests, consuming its resources and causing service degradation, or keeping multiple long connections open (Slowloris Attack)
- How to prevent/overcome?
  - Computational challenge (e.g., captcha)
  - Web Application Firewall (WAF)
  - Manage IP reputation database to track and selectively block malicious traffic



© iSilva 2026

DDoS attacks – Application layer attacks (2/3)

- Other attacks more focused on server/client side (not properly DDoS)
- HTTP/HTTPS agnostic

SQL injection (SQLi)

- attacker exploits vulnerabilities in web apps to execute malicious SQL queries, which may lead to database overload or data leakage
  - or vulnerabilities of APIs by sending apparently legitimate requests
- How to prevent/overcome?
  - **Parameterized Queries (Prepared Statements):** Treat user input strictly as data rather than executable code. Most modern frameworks handle this natively.
  - **Input Validation:** Use an "allow-list" to verify that incoming data matches expected types, lengths, and character sets (e.g., ensuring a user ID is strictly numeric).
  - **Stored Procedures:** Similar to prepared statements, these pre-compile SQL queries on the database server. Ensure the stored procedure uses parameters safely and does not concatenate unvalidated dynamic strings internally.
  - **Principle of Least Privilege:** Limit database accounts to the minimum permissions required. A web application should never connect as a database administrator or use `sa` rights.

© iSilva 2026

DDoS attacks – Application layer attacks (3/3)

Cross Site Scripting (XSS)

- attacker injects malicious code into a webpage, stealing cookies or running code (usually JS) in the victim's browser
- How to prevent/overcome?
  - **Output Encoding**: Convert user-supplied data into a safe format (like HTML entities) before rendering it in the browser so it is treated as text, not executable code.
  - **Context-Aware Sanitization**: Use trusted libraries (like DOMPurify) to strip out malicious scripts if you must allow users to input rich HTML text.
  - **Strict Input Validation**: Implement strict whitelisting to accept only expected data formats (e.g., numbers, alphanumeric characters) and reject everything else.
  - **Content Security Policy (CSP)**: Deploy a strong HTTP `Content-Security-Policy` header to restrict where scripts can be loaded from and block unauthorized inline scripts.
  - **HttpOnly Cookies**: Protect session tokens by applying the `HttpOnly` flag to cookies, preventing client-side scripts from accessing or stealing them.
  - **Framework Security Features**: Rely on modern web frameworks (like React, Angular, or Vue) that automatically encode data by default.

© iSilva 2026

MitM attacks across network layers

Application layer

- Attacks manipulate application data or user requests to mislead users, inject content, or force weaker security.
- e.g. DNS spoofing, HTTP flooding, downgrade, malicious JS injection

Transport layer

- Attacks interfere with end-to-end sessions by resetting, delaying, replaying, or weakening transport level protection.
- e.g. truncation (reset), replay, reordering, downgrade

Network layer

- Attacks alter packet delivery paths so traffic is redirected through the attacker or sent to the wrong destination
- e.g. IP spoofing, ICMP redirects, forge route advertisements

Link layer

- Attacks abuse local network protocols to impersonate devices and position the attacker between hosts on the same network.
- e.g., ARP spoofing, ARP poisoning, rogue/fake AP, DHCP spoofing

Physical layer

- Attacks target the transmission medium itself by disrupting signals or directly capturing transmitted data.
- e.g. jamming, side channel attacks, medium tapping (intercepting cable/radio)

© iSilva 2026